

Cyber Security — Complete Theory Exam Notes

1. Importance of cyber security in modern organizations

Cyber Security is the practice of protecting computers, networks, applications, systems, and data from unauthorized access, cyberattacks, damage, theft, or disruption. Its main purpose is to protect information and ensure the confidentiality, integrity, and availability of computer resources.

Importance of Cyber Security in Modern Organizations

Modern organizations depend heavily on computers, networks, cloud services, and digital information. Cyber security is important because it:

- **Protects sensitive data:** Prevents unauthorized access to customer, employee, financial, and business information.
- **Prevents financial loss:** Reduces losses caused by ransomware, fraud, data theft, and service disruption.
- **Maintains business continuity:** Protects systems against attacks that could stop business operations.
- **Protects reputation:** Security breaches can damage customer trust and organizational reputation.
- **Ensures privacy:** Protects personal and confidential information.
- **Supports legal compliance:** Helps organizations follow security and privacy requirements.
- **Protects against cyber threats:** Reduces risks from malware, phishing, DDoS, and unauthorized access.

Security Goals (CIA Triad) with examples

The CIA Triad is a fundamental model in cybersecurity. It represents three main security goals: Confidentiality, Integrity, and Availability.

1. Confidentiality

Confidentiality ensures that information is accessible only to authorized users and prevents unauthorized disclosure.

Examples:

- Using passwords to protect accounts.
- Encrypting sensitive files and messages.
- Allowing only authorized employees to access company data.
- Using access control and authentication.

Example scenario:

A banking app encrypts customer account information so unauthorized people cannot read it.

2. Integrity

Definition:

Integrity ensures that information remains **accurate, complete, and unchanged** unless modified by an authorized person or process.

Examples:

- Using hashes to detect file modification.
- Using digital signatures to verify data authenticity.
- Restricting who can edit important records.
- Maintaining audit logs to track changes.

Example scenario:

A university system prevents students from changing their own exam grades.

3. Availability**Definition:**

Availability ensures that systems, services, and data are **accessible to authorized users when needed**.

Examples:

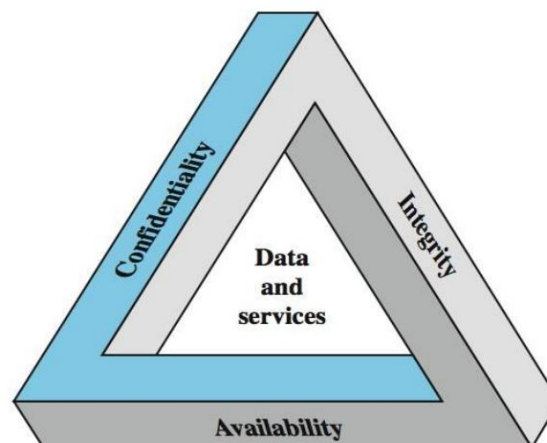
- Keeping regular backups.
- Using redundant servers.
- Protecting systems against DDoS attacks.
- Using backup power supplies during power failures.

Example scenario:

An online banking service uses backup servers so customers can access their accounts even if one server fails.

2. CIA Triad

The CIA Triad is a fundamental information security model consisting of Confidentiality, Integrity, and Availability.

**1. Confidentiality**

Confidentiality ensures that information is accessible only to authorized users and prevents unauthorized disclosure.

Methods: Encryption, authentication, passwords, and access control.

Example: Only authorized bank employees can view customer account information.

2. Integrity

Integrity ensures that information remains accurate, complete, and protected from unauthorized modification or deletion.

Methods: Hashing, digital signatures, checksums, and access controls.

Example: An attacker should not be able to change a customer's bank balance.

3. Availability

Availability ensures that systems, services, and information are accessible to authorized users whenever required.

Methods: Backups, redundancy, disaster recovery, load balancing, and DDoS protection.

Example: An online banking service should remain accessible to customers 24/7.

Easy way to remember

C → Keep data **secret**

I → Keep data **correct**

A → Keep data **accessible**

3. Trojan Horse

A Trojan Horse is malware that is disguised as useful or legitimate software but performs hidden malicious activities when the user executes it. Unlike viruses and worms, a Trojan does not self-replicate.

How It Works

1. Attacker disguises malware as legitimate software.
2. User downloads and runs it.
3. The malicious code executes secretly.
4. It may steal information, install malware, or provide unauthorized access.

Characteristics

- Appears legitimate.
- Usually requires user action.
- Does not self-replicate.
- Can steal passwords and sensitive information.
- May create a backdoor for attackers.

Example: A fake game installer that secretly installs malware.

4. Cryptography

Definition

Cryptography is the science of protecting information by transforming readable data (plaintext) into an unreadable form (ciphertext) using mathematical algorithms and keys.

Encryption:

$$\text{Plaintext} + \text{Key} \rightarrow \text{Ciphertext}$$

Decryption:

$$\text{Ciphertext} + \text{Key} \rightarrow \text{Plaintext}$$

Uses / Applications of Cryptography

Cryptography is used to **protect information and communication** from unauthorized access, modification, and misuse.

1. Data Confidentiality

Cryptography protects sensitive information from unauthorized users by converting plaintext into unreadable ciphertext. **Example:** Encrypting files stored on a computer or cloud storage.

2. Secure Communication

It protects data transmitted over networks from being read by attackers. **Example:** HTTPS encrypts communication between a web browser and a website.

3. Authentication

Cryptography helps verify the **identity of a user, device, or system**. **Example:** Cryptographic authentication is used when securely logging into an online service.

4. Data Integrity

It helps ensure that data has **not been altered or tampered with** during storage or transmission.

Example: A hash can be used to check whether a downloaded file has been modified.

5. Digital Signatures

Digital signatures verify the **authenticity and integrity** of digital documents or messages. **Example:** Digitally signing an electronic contract.

6. Password Protection

Systems commonly store **cryptographic hashes of passwords** instead of storing passwords in plaintext.

Example: A website compares a securely derived password hash during login rather than storing the original password.

7. Secure Online Transactions

Cryptography protects sensitive information during **online banking, payments, and e-commerce transactions**. **Example:** Protecting payment information while making an online purchase.

8. Secure Email and Messaging

Cryptography can protect private messages from unauthorized access. **Example:** End-to-end encryption in messaging applications.

9. Software and Update Verification

Cryptographic signatures help verify that software or updates come from a **trusted source and have not been modified**. **Example:** An operating system verifies a signed software update before installing it.

10. Digital Certificates

Cryptography is used in digital certificates to establish **trusted identities and secure connections**.

Example: TLS certificates help browsers authenticate websites and establish encrypted HTTPS connections.

5. Substitution Cipher

Definition

A Substitution Cipher is an encryption technique in which each plaintext letter or group of letters is replaced by another letter, symbol, or group of symbols, while the original order of positions is generally maintained.

Example — Caesar Cipher:

Plaintext: HELLO

Ciphertext: KHOOR

Each letter is shifted by 3.

Examples

- Caesar Cipher
- Monoalphabetic Cipher
- Vigenère Cipher
- Playfair Cipher

Substitution vs Transposition

Substitution Cipher	Transposition Cipher
Replaces characters	Rearranges characters
Character identity changes	Character identity remains unchanged
Positions generally remain	Positions change
Changes letter frequencies' labels	Preserves the same letter counts
Caesar is an example	Columnar Transposition is an example

6. Transposition Cipher

Definition

A Transposition Cipher is an encryption method in which the characters of plaintext are rearranged according to a particular rule or key without changing the characters themselves.

For example:

Plaintext: ABCDEF

Ciphertext: BADCFE

The letters remain the same, but their positions change.

Characteristics

- Characters are not replaced.
- Their positions are rearranged.
- Uses a key or permutation rule.
- Preserves the frequency of each character.

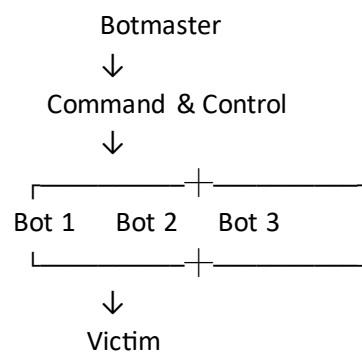
Examples

- Rail Fence Cipher
- Columnar Transposition Cipher
- Permutation Cipher

7. Botnet

A Bot (also called a Zombie) is a computer that has been infected with malware and is secretly controlled by an attacker without the owner's knowledge. The infected computer appears normal to the user but continuously communicates with the attacker's server to receive commands.

Botnet Architecture



Components of a Botnet

1. Botmaster

- Controls the entire botnet.
- Sends commands to infected computers.

2. Bots (Zombies)

- Compromised computers.
- Execute malicious instructions.

3. C&C Server

- Communication channel between botmaster and bots.
- Sends updates and attack commands.

4. Victim

- Target of attacks such as DDoS or spam. How a Botnet is Created

Step 1

Attacker develops malware.

↓

Step 2

Malware spreads through:

- Email attachments
- Malicious websites
- Fake software
- USB drives
- Social engineering

↓

Step 3

Victim executes malware.

↓

Step 4

Computer becomes a Bot.

↓

Step 5

Bot connects to C&C server.

↓

Step 6

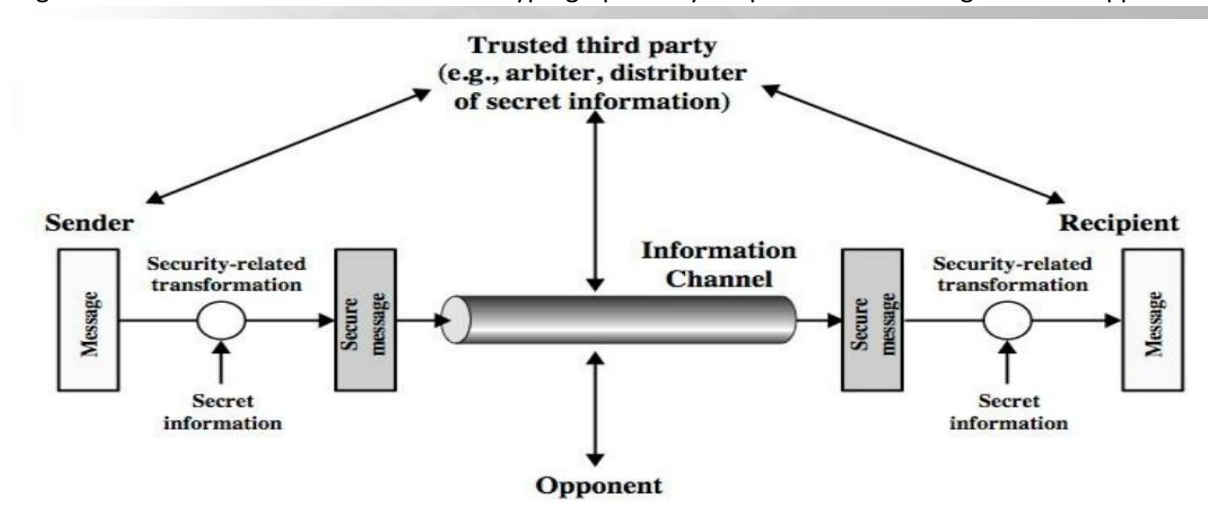
Attacker controls thousands of infected computers.

Uses of Botnets

- DDoS attacks
- Sending spam
- Phishing
- Information theft
- Click fraud
- Malware distribution

8. Model of Network Security

The Model of Network Security is a framework that explains how a sender and recipient communicate securely over an insecure network. It uses security-related transformations, such as encryption, together with secret information such as cryptographic keys to protect the message from an opponent.



An attacker may attempt to intercept, modify, or fabricate information while it travels through the network.

Main Components

- 1. Sender:** The sender is the person or system that creates the original message and wants to transmit it securely.
- 2. Message:** The message is the original information that the sender wants to send to the recipient.
- 3. Security-Related Transformation:** Before transmission, the message passes through a security transformation such as encryption, digital signature, or authentication mechanism. This converts or protects the original message.
- 4. Secret Information:** Secret information, usually a cryptographic key, is used with the security transformation. The correct key is required to perform or reverse the transformation.
- 5. Secure Message:** After applying the security transformation, the original message becomes a protected or secure message, such as ciphertext in the case of encryption.
- 6. Information Channel:** The secure message travels through the communication network or information channel. Since the channel may be insecure, an attacker may try to intercept or modify the message.
- 7. Opponent:** The opponent or attacker attempts to compromise communication by intercepting, modifying, deleting, or creating messages.
- 8. Recipient:** The recipient receives the secure message and applies the appropriate security-related transformation using the required key to recover or verify the original message.
- 9. Trusted Third Party:** A Trusted Third Party (TTP) helps the sender and recipient establish secure communication. It may distribute secret keys, issue certificates, verify identities, or act as an arbiter.

9. RSA Algorithm

Definition

RSA (Rivest-Shamir-Adleman) is an asymmetric public-key cryptographic algorithm that uses a public key and a private key. Its security is based on the practical difficulty of factoring a sufficiently large number that is the product of two large primes.

RSA Key Generation

Step 1: Choose two primes

$$p, q$$

Step 2: Calculate n

$$n = pq$$

Step 3: Calculate Euler's totient

$$\phi(n) = (p - 1)(q - 1)$$

Step 4: Choose e

Choose:

$$1 < e < \phi(n)$$

such that:

$$\gcd(e, \phi(n)) = 1$$

Step 5: Find d

$$ed \equiv 1 \pmod{\phi(n)}$$

Public key:

$$(e, n)$$

Private key:

$$(d, n)$$

Encryption

$$C = M^e \bmod n$$

Decryption

$$M = C^d \bmod n$$

Mathematical Example

Take:

$$p = 3, q = 11$$

Then:

$$n = 3 \times 11 = 33$$
$$\phi(n) = 2 \times 10 = 20$$

Choose:

$$e = 3$$

Find d:

$$3d \equiv 1 \pmod{20}$$

So:

$$d = 7$$

Therefore:

Public Key: (3, 33)

Private Key: (7, 33)

If:

$$M = 4$$

Encryption:

$$C = 4^3 \bmod 33 = 64 \bmod 33 = \boxed{31}$$

Decryption:

$$M = 31^7 \bmod 33 = \boxed{4}$$

Advantages of RSA

1. **Strong Security** – RSA provides strong security when sufficiently large keys and proper padding are used.
2. **Public-Key Cryptography** – It uses a public key and private key, so the private key does not need to be shared.
3. **Secure Key Exchange** – RSA can securely transport or establish keying material when used with appropriate modern protocols/padding.
4. **Digital Signatures** – RSA can be used to create and verify digital signatures, providing authentication and integrity.
5. **No Shared Secret Required Initially** – Two parties can communicate securely without first sharing the same secret key.
6. **Widely Supported** – RSA is a well-established algorithm supported by many security systems, libraries, and protocols.
7. **Authentication** – RSA signatures can help verify the identity of the sender and confirm that a message came from the expected source.
8. **Easy Public-Key Distribution** – The public key can be openly distributed, while only the private key needs to remain secret.

10. Plaintext

Definition

Plaintext is the original, readable information before it is encrypted by a cryptographic algorithm.

For example:

Plaintext: HELLO

↓ Encryption

Ciphertext: KHOOR

After decryption, ciphertext is converted back into plaintext.

Plaintext can be:

- Text
- Email messages
- Documents
- Images
- Other digital information

If your handwritten topic says "**3 mail**" rather than something related to plaintext/email, that part would need the original image to determine the exact topic.

11. Steganography

Definition

Steganography is the technique of hiding secret information inside another ordinary-looking medium, such as an image, audio file, video, or document, so that the existence of the secret message is concealed.

Example:

Secret Message

↓

Hidden inside image

↓

Normal-looking Image

Steganography vs Cryptography

Cryptography	Steganography
Hides the meaning of information	Hides the existence of information
Plaintext becomes ciphertext	Message is hidden inside another medium
Ciphertext looks unreadable	Carrier may appear normal
Uses encryption algorithms and keys	Uses hiding/embedding techniques
Example: AES, RSA	Example: hiding text in an image

They can also be combined: first **encrypt the message**, then **hide the ciphertext** inside another medium.

12. Diffie–Hellman Key Exchange

Diffie–Hellman Key Exchange is a public-key technique that allows two parties to establish a shared secret key over an insecure communication channel without directly transmitting the secret key itself. Its security relies on the difficulty of the discrete logarithm problem in an appropriate group.

Working

Alice and Bob publicly agree on:

- Prime number q
- Primitive root α

Alice chooses private key:

$$A$$

Bob chooses private key:

$$B$$

Alice calculates:

$$Y_A = \alpha^A \bmod q$$

Bob calculates:

$$Y_B = \alpha^B \bmod q$$

They exchange Y_A and Y_B .

Alice calculates:

$$K = Y_B^A \bmod q$$

Bob calculates:

$$K = Y_A^B \bmod q$$

Both obtain the same shared secret.

Mathematical Example

Given:

$$q = 23, \alpha = 5$$

Example

Alice:

$$A = 6$$

Bob:

$$B = 15$$

Alice's public value:

$$Y_A = 5^6 \bmod 23 = 8$$

Bob's public value:

$$Y_B = 5^{15} \bmod 23 = 19$$

Alice calculates the shared secret:

$$K = 19^6 \bmod 23$$

$$\boxed{K = 2}$$

Bob also calculates:

$$K = 8^{15} \bmod 23$$

$$\boxed{K = 2}$$

Thus both establish the secret key **2**.

Limitation

Basic Diffie-Hellman does not authenticate the parties, so it can be vulnerable to a Man-in-the-Middle attack unless authentication is added.

13. Vernam Cipher / One-Time Pad

Vernam Cipher Definition

The Vernam Cipher is a polyalphabetic substitution cipher that uses a key whose length is equal to the length of the plaintext. Each plaintext letter is combined with the corresponding key letter to produce the ciphertext.

- Originally proposed using a very long repeating key.
- The ideal version, using a truly random non-repeating key, is called the One-Time Pad.

Main Idea

Unlike the Vigenère Cipher, the key is not repeated. Instead, the key length must be exactly the same as the plaintext length.

Example

Plaintext

HELLO

Key

XMCKL

Both contain five letters.

One-Time Pad (OTP)

The One-Time Pad (OTP) is an unconditionally secure encryption technique that uses a random secret key with the same length as the plaintext. Each key is used only once and then discarded. It provides perfect secrecy, meaning the ciphertext cannot be broken even with unlimited computing power. A One-Time Pad is a special form of the Vernam cipher that provides perfect secrecy when the key satisfies all of these conditions:

- The key is truly random.
- The key is as long as the plaintext.
- The key is used only once.
- The key is kept completely secret.

If these conditions are satisfied, the ciphertext alone provides no information that allows an attacker to determine which plaintext was sent.

Limitation

Secure generation, distribution, storage, and management of long one-time keys are difficult.

14. Playfair Cipher

Definition

The Playfair Cipher is a substitution cipher that encrypts pairs of letters (digraphs) instead of encrypting individual letters.

It uses a **5×5 key matrix**, normally combining I and J.

Example

Key:

MONARCHY

Matrix:

M O N A R

C H Y B D

E F G I K

L P Q S T

U V W X Z

Plaintext:

INSTRUMENT

Pairs:

IN ST RU ME NT

Rules

Same row: Replace each letter with the letter to its right.

Same column: Replace each with the letter below it.

Different rows and columns: Use the rectangle rule and replace each letter with the letter in its own row and the other letter's column.

For the example:

IN → GA

ST → TL

RU → MZ

ME → CL

NT → RQ

Therefore:

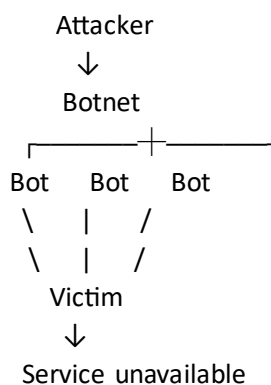
GATLMZCLRQ

15. DDoS Attack

Definition

A Distributed Denial-of-Service (DDoS) attack is a cyberattack where many compromised devices simultaneously send large amounts of traffic or requests to a target system, exhausting its resources and making the service unavailable to legitimate users.

Working



Effects

- **Service Unavailability:** Websites or online services may become completely inaccessible.
- **Network Congestion:** Excessive malicious traffic consumes available network bandwidth.
- **Resource Exhaustion:** Server resources such as CPU, memory, bandwidth, and connection limits can be exhausted.
- **Slow Performance:** Applications and websites may respond very slowly even if they remain online.
- **Business Disruption:** Normal business activities, online transactions, and customer services may be interrupted.
- **Financial Loss:** Downtime, recovery work, lost transactions, and mitigation can create significant costs.
- **Reputation Damage:** Frequent or prolonged outages can reduce customer trust in an organization.
- **Security Distraction:** A DDoS attack can sometimes distract security teams while attackers attempt other malicious activities.

DoS vs DDoS

DoS: One primary attacking source.

DDoS: Many distributed attacking devices.

16. Permutation Cipher

Definition

A Permutation Cipher is a type of transposition cipher in which plaintext characters are rearranged according to a predefined permutation or key, while the characters themselves remain unchanged.

Example:

Plaintext:

ABCD

Permutation:

3 1 4 2

Rearranging positions gives:

CADB

Types

1. Simple/Block Permutation

The plaintext is divided into fixed-size blocks, and positions within each block are rearranged using the same permutation.

2. Columnar Transposition

Plaintext is written into rows under a keyword, and columns are read in the order determined by the key.

Core Concept

Original characters

↓

Rearrange positions using key

↓

Ciphertext

No character needs to be replaced; only its **position changes**.

17. Caesar Cipher

Definition

The Caesar Cipher is a monoalphabetic substitution cipher in which every plaintext letter is shifted by a fixed number of positions in the alphabet.

For shift 3:

A → D

B → E

C → F

Example:

Plaintext: HELLO

Ciphertext: KHOOR

Formula

Encryption:

$$C = (P + k) \bmod 26$$

Decryption:

$$P = (C - k) \bmod 26$$

where k is the shift key.

Weaknesses

- Only 25 nontrivial shifts.
- Easy brute-force attack.
- Vulnerable to frequency analysis.
- Same plaintext letter always maps to the same ciphertext letter.

18. Symmetric vs Asymmetric Cryptography

Symmetric Cryptography

Symmetric cryptography uses the same secret key for encryption and decryption.

Examples:

- AES
- DES

Asymmetric Cryptography

Asymmetric cryptography uses a pair of mathematically related keys:

- Public key
- Private key

Examples:

- RSA
- ECC

Comparison

Symmetric vs Asymmetric Cryptography

Symmetric Cryptography	Asymmetric Cryptography
Uses one key for encryption and decryption.	Uses two keys: public key and private key.
Same key must be shared between sender and receiver.	Public key can be shared openly; private key is kept secret.
Faster and requires less computation.	Slower and requires more computation.
Suitable for encrypting large amounts of data.	Commonly used for key establishment and digital signatures.
Key distribution is more difficult because the secret key must be shared securely.	Key distribution is easier because the public key does not need to be secret.
Generally uses smaller keys for comparable practical security within its algorithm family.	Generally uses larger keys than symmetric cryptography.
Does not inherently provide digital signatures.	Can provide digital signatures and authentication.
Examples: AES, DES, 3DES, ChaCha20.	Examples: RSA, ECC, ElGamal.

19. Digital Signature

Definition

A Digital Signature is a cryptographic technique used to verify the identity of the sender and ensure that a digital message or document has not been changed after it was signed. It is created using the sender's private key and verified using the sender's public key.

Purpose of Digital Signature

The main purposes are:

- **Authentication:** Confirms the identity of the signer.
- **Integrity:** Ensures that the message or document has not been modified after signing.

- **Non-repudiation:** Provides evidence that the signer approved or signed the message, so they cannot easily deny it later.

Authentication Using Digital Signature

Digital signatures provide authentication by proving that the signature was generated using the private key corresponding to the sender's public key.

The process works as follows:

1. The sender creates a **hash** of the original message.
2. The sender signs that hash using their **private key**, producing the digital signature.
3. The sender sends the **message and digital signature** to the receiver.
4. The receiver uses the sender's **public key** to verify the signature.
5. The receiver also calculates a new hash of the received message.
6. If verification succeeds and the hashes match, the receiver knows that the message has not been altered and was signed by the holder of the corresponding private key.

Simple Flow

Sender:

Message → Hash → Sign with Private Key → Digital Signature

Receiver:

Message → Hash —————→ Compare / Verify
 Signature → Verify with Public Key —————→ Compare / Verify

Example

Suppose Alice digitally signs a document using her private key. Bob verifies the signature using Alice's public key. If verification succeeds, Bob has evidence that the document was signed using Alice's private key and that the signed document has not been modified.

In short:

Digital Signature = Authentication + Integrity + Non-repudiation